



**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN**

**BÁO CÁO TIỂU LUẬN CUỐI KỲ
HỌC PHẦN: BẢO MẬT IoT**

**TÊN ĐỀ TÀI
QUẢN LÝ RỦI RO BẢO MẬT CHO HỆ THỐNG IoT QUY MÔ NHỎ**

Mã đề tài
35
Mã học phần / Lớp học phần
INT4410
Giảng viên hướng dẫn
Hồ Nhật Minh
Sinh viên thực hiện
Võ Nguyễn Duyên
MSSV
231A010722
Link repo GitHub
[Dán đường dẫn repo tại đây]
Ngày nộp
[dd/mm/yyyy]

TP. HỒ CHÍ MINH, 2026

THÔNG TIN VÀ CAM KẾT NỘP BÀI

Tên đề tài

Quản lý rủi ro bảo mật cho hệ thống IoT quy mô nhỏ

Mã đề tài

35

Sinh viên/Nhóm

Võ Nguyễn Duyên - 231A010722

Repo GitHub

[Đán đường dẫn repo tại đây]

Bản báo cáo

231A010722_VoNguyenDuyen_35_BaoCao.docx

Bản trình chiếu

231A010722_VoNguyenDuyen_35_Slide.pptx

Sản phẩm chính

Risk register, ma trận rủi ro 5x5, kế hoạch xử lý, checklist kiểm tra định kỳ

Ngày nộp

[dd/mm/yyyy]

Cam kết an toàn và học thuật

Tôi cam kết toàn bộ thử nghiệm được thực hiện trong môi trường cục bộ, dữ liệu giả lập/được phép; không quét, khai thác hay thu thập dữ liệu từ hệ thống thật. Báo cáo, mã nguồn và minh chứng là kết quả làm việc của cá nhân tôi; mọi nội dung kế thừa đều được trích dẫn rõ ràng. Repo không chứa secret, token, mật khẩu hoặc dữ liệu cá nhân thật.

Họ tên người cam kết: Võ Nguyễn Duyên

Ngày cam kết: [.../.../.....]

Chữ ký: [.....]

MỤC LỤC

1. MỞ ĐẦU.....	8
1.1. Bối cảnh và lý do chọn đề tài.....	8
1.2. Phát biểu vấn đề.....	8
1.3. Mục tiêu.....	8
1.4. Đối tượng và phạm vi.....	9
1.5. Sản phẩm dự kiến và đóng góp.....	9
2. CƠ SỞ LÝ THUYẾT VÀ NGUỒN LIÊN QUAN.....	9
2.1. Kiến trúc, giao thức hoặc công nghệ nền.....	9
2.2. Khái niệm bảo mật liên quan.....	10
2.3. Chuẩn, tài liệu và công cụ GitHub.....	11
2.4. Công trình/giải pháp liên quan.....	12
3. PHƯƠNG PHÁP VÀ THIẾT KẾ.....	12
3.1. Phương pháp thực hiện.....	12
3.2. Kiến trúc/mô hình và luồng dữ liệu.....	12
3.3. Môi trường, công cụ và dữ liệu.....	13
3.4. Quy trình thực hiện.....	13
3.5. Giới hạn an toàn và đạo đức.....	14
4. TRIỂN KHAI VÀ SẢN PHẨM.....	14
4.1. Chuẩn bị môi trường.....	14
4.2. Thành phần sản phẩm.....	15
4.3. Kịch bản thử nghiệm/đánh giá.....	15
4.4. Hướng dẫn chạy hoặc sử dụng sản phẩm.....	16
5. KẾT QUẢ VÀ THẢO LUẬN.....	16
5.1. Kết quả chính.....	16
5.2. Bảng tổng hợp kết quả.....	17
5.3. Đối chiếu mục tiêu.....	18
5.4. Hạn chế.....	18
6. ĐÁNH GIÁ BẢO MẬT.....	18
6.1. Tài sản và dữ liệu cần bảo vệ.....	18
6.2. Mối đe dọa và lỗ hổng.....	19
6.3. Ma trận rủi ro.....	20
6.4. Biện pháp giảm thiểu và ưu tiên.....	21
6.5. Đánh giá an toàn sau xử lý.....	22
7. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN.....	22
7.1. Kết luận.....	22
7.2. Hướng phát triển.....	22
TÀI LIỆU THAM KHẢO.....	23

PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP.....24

PHỤ LỤC B. NHẬT KÝ ĐÓNG GÓP.....24

PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP.....24

PHỤ LỤC D. PHIẾU TỰ ĐÁNH GIÁ THEO RUBRIC.....24

PHỤ LỤC E. CÂU HỎI CHUẨN BỊ BẢO VỆ.....25

PHỤ LỤC F. ĐỐI CHIẾU ĐỀ TÀI ĐƯỢC GIAO.....25

(Số trang tham khảo theo bản in hiện tại — vào Insert > Field > Page nếu muốn Word tự cập nhật lại số trang sau khi chỉnh sửa thêm.)

DANH MỤC BẢNG

Bảng 6.1. Danh mục tài sản của hệ thống IoT quy mô nhỏ

Bảng 6.2. Sổ đăng ký rủi ro (Risk Register)

Bảng 6.3. Ma trận đánh giá rủi ro 5×5

Bảng 6.4. Kế hoạch xử lý 5 rủi ro có mức độ cao nhất

Bảng 6.5. Checklist kiểm tra bảo mật định kỳ

Bảng 5.2. Bảng tổng hợp kết quả theo mục tiêu

DANH MỤC HÌNH ẢNH

Hình 2.1. Kiến trúc tổng thể hệ thống IoT quy mô nhỏ

Hình 2.2. Quy trình quản lý rủi ro

Hình 3.1. Kiến trúc đề xuất của hệ thống IoT quy mô nhỏ

Hình 3.2. Quy trình triển khai đánh giá rủi ro

Hình 5.1. Kết quả lập danh mục tài sản của hệ thống IoT

Hình 5.2. Kết quả xây dựng Risk Register

Hình 5.3. Ma trận đánh giá rủi ro 5×5

DANH MỤC TỪ VIẾT TẮT

Viết tắt	Ý nghĩa
IoT	Internet of Things
CIA	Confidentiality – Integrity – Availability
MFA	Multi-Factor Authentication
VPN	Virtual Private Network
TLS	Transport Layer Security
HTTPS	HyperText Transfer Protocol Secure
MQTT	Message Queuing Telemetry Transport
OWASP	Open Worldwide Application Security Project
NIST	National Institute of Standards and Technology
ISVS	IoT Security Verification Standard

1. MỞ ĐẦU

1.1. Bối cảnh và lý do chọn đề tài

Internet of Things (IoT) đang phát triển mạnh mẽ và được ứng dụng rộng rãi trong nhiều lĩnh vực như nhà thông minh, nông nghiệp, y tế, giáo dục và doanh nghiệp. Các thiết bị IoT có khả năng thu thập, truyền tải và xử lý dữ liệu theo thời gian thực, góp phần nâng cao hiệu quả quản lý và tối ưu chi phí vận hành.

Tuy nhiên, các hệ thống IoT quy mô nhỏ vẫn tiềm ẩn nhiều nguy cơ mất an toàn thông tin do hạn chế về chi phí và khả năng quản trị. Nhiều thiết bị còn sử dụng mật khẩu mặc định, chưa cập nhật firmware thường xuyên, thiếu cơ chế xác thực và mã hóa dữ liệu, làm tăng nguy cơ truy cập trái phép, rò rỉ dữ liệu và bị tấn công mạng.

Theo OWASP Internet of Things Security Project (2024), các lỗ hổng phổ biến của IoT gồm mật khẩu mặc định, cấu hình không an toàn và thiếu cơ chế cập nhật firmware. NIST SP 800-30 Revision 1 (2012) cũng khuyến nghị đánh giá rủi ro thông qua việc nhận diện tài sản, xác định mối đe dọa, đánh giá tác động và đề xuất biện pháp giảm thiểu.

Xuất phát từ thực tế trên, đề tài "Quản lý rủi ro bảo mật cho hệ thống IoT quy mô nhỏ" được thực hiện nhằm nhận diện tài sản, phân tích mối đe dọa và lỗ hổng bảo mật, đánh giá mức độ rủi ro, từ đó đề xuất các biện pháp giảm thiểu phù hợp với điều kiện triển khai thực tế.

1.2. Phát biểu vấn đề

Hệ thống IoT quy mô nhỏ gồm nhiều tài sản quan trọng như thiết bị IoT, dữ liệu cảm biến, firmware, tài khoản quản trị và hạ tầng mạng. Do hạn chế về chi phí và khả năng quản trị, các hệ thống này thường tồn tại nhiều lỗ hổng như mật khẩu yếu, firmware chưa cập nhật, thiếu cơ chế mã hóa và xác thực, làm gia tăng nguy cơ truy cập trái phép, rò rỉ dữ liệu và tấn công mạng.

Nếu không được đánh giá và kiểm soát kịp thời, các rủi ro này sẽ ảnh hưởng đến tính bí mật, tính toàn vẹn và tính sẵn sàng của hệ thống. Vì vậy, đề tài tập trung xây dựng mô hình quản lý rủi ro bảo mật cho hệ thống IoT quy mô nhỏ thông qua việc nhận diện tài sản, xác định mối đe dọa, xây dựng Risk Register, đánh giá rủi ro bằng ma trận 5×5 và đề xuất các biện pháp giảm thiểu phù hợp.

1.3. Mục tiêu

Đề tài được thực hiện nhằm đạt được các mục tiêu sau:

- MT-01: Xác định và phân loại các tài sản quan trọng trong hệ thống IoT quy mô nhỏ.
- MT-02: Phân tích các mối đe dọa, lỗ hổng và đánh giá mức độ rủi ro đối với từng tài sản.
- MT-03: Xây dựng Risk Register và ma trận đánh giá rủi ro 5×5 .
- MT-04: Đề xuất các biện pháp xử lý và giảm thiểu rủi ro có mức độ cao.
- MT-05: Xây dựng checklist kiểm tra bảo mật định kỳ cho hệ thống IoT.

1.4. Đối tượng và phạm vi

Đối tượng nghiên cứu: Hệ thống IoT quy mô nhỏ gồm thiết bị IoT, gateway, dữ liệu cảm biến, tài khoản quản trị và hạ tầng mạng.

Phạm vi nghiên cứu: Đề tài đánh giá rủi ro trên mô hình IoT giả lập, tham khảo các tiêu chuẩn OWASP IoT Security Project và NIST SP 800-30 để đề xuất giải pháp bảo mật.

Giới hạn nghiên cứu: Đề tài không thực hiện tấn công trên thiết bị IoT thực tế, không thu thập dữ liệu cá nhân và chỉ tập trung vào việc nhận diện, đánh giá và quản lý rủi ro bảo mật.

1.5. Sản phẩm dự kiến và đóng góp

Sau khi hoàn thành, đề tài dự kiến đạt được các sản phẩm sau:

- Sơ đồ kiến trúc tổng thể của hệ thống IoT quy mô nhỏ.
- Danh sách các tài sản cần bảo vệ trong hệ thống.
- Risk Register gồm tối thiểu 15 rủi ro bảo mật.
- Ma trận đánh giá rủi ro 5×5.
- Kế hoạch xử lý và giảm thiểu đối với 5 rủi ro có mức độ cao.
- Checklist kiểm tra bảo mật định kỳ cho hệ thống IoT.
- README mô tả phạm vi nghiên cứu, nguồn tài liệu tham khảo và hướng dẫn sử dụng các sản phẩm của đề tài.

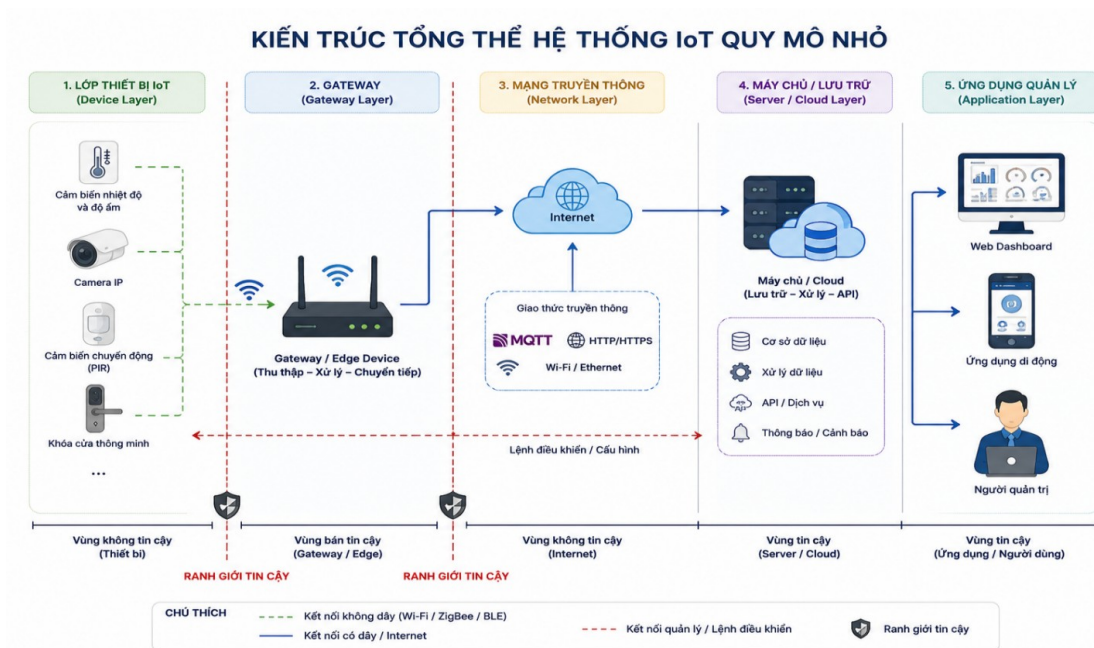
2. CƠ SỞ LÝ THUYẾT VÀ NGUỒN LIÊN QUAN

2.1. Kiến trúc, giao thức hoặc công nghệ nền

Hệ thống IoT quy mô nhỏ trong phạm vi đề tài được xây dựng theo mô hình gồm 5 thành phần chính: lớp thiết bị IoT, gateway, mạng truyền thông, máy chủ/lưu trữ và ứng dụng quản lý (Hình 2.1). Đây là mô hình phổ biến trong các hộ gia đình, phòng thí nghiệm và doanh nghiệp nhỏ, cho phép thu thập, truyền tải và quản lý dữ liệu từ các thiết bị IoT.

Ở lớp thiết bị, các cảm biến, camera IP và khóa thông minh thực hiện thu thập dữ liệu hoặc điều khiển thiết bị. Dữ liệu được gateway tiếp nhận, xử lý sơ bộ và truyền qua mạng bằng các giao thức như MQTT hoặc HTTP/HTTPS đến máy chủ để lưu trữ, xử lý và cung cấp dịch vụ. Người quản trị có thể giám sát và điều khiển hệ thống thông qua giao diện web hoặc ứng dụng di động.

Trong kiến trúc này, dữ liệu truyền giữa các thành phần cần được bảo vệ bằng các cơ chế xác thực, mã hóa và kiểm soát truy cập nhằm hạn chế nguy cơ truy cập trái phép, nghe lén hoặc giả mạo dữ liệu. Các ranh giới tin cậy trong hệ thống cũng là cơ sở để xác định tài sản và đánh giá rủi ro.



Hình 2.1. Kiến trúc tổng thể hệ thống IoT quy mô nhỏ. Nguồn: ChatGPT (OpenAI), nhóm tác giả hiệu chỉnh (2026).

2.2. Khái niệm bảo mật liên quan

Tài sản (Asset): Tài sản là những thành phần có giá trị cần được bảo vệ trong hệ thống. Đối với hệ thống IoT, tài sản bao gồm thiết bị IoT, gateway, dữ liệu cảm biến, tài khoản quản trị, firmware, khóa mã hóa và hạ tầng mạng.

Mối đe dọa (Threat): Mối đe dọa là các sự kiện hoặc hành động có khả năng khai thác điểm yếu của hệ thống và gây ảnh hưởng đến hoạt động bình thường. Một số mối đe dọa phổ biến gồm truy cập trái phép, giả mạo thiết bị, phát tán mã độc, tấn công từ chối dịch vụ (DoS) và nghe lén dữ liệu.

Lỗ hổng (Vulnerability): Lỗ hổng là điểm yếu tồn tại trong thiết bị, phần mềm hoặc quy trình quản lý có thể bị kẻ tấn công khai thác. Ví dụ như sử dụng mật khẩu mặc định, firmware chưa cập nhật, cấu hình sai hoặc giao tiếp không được mã hóa.

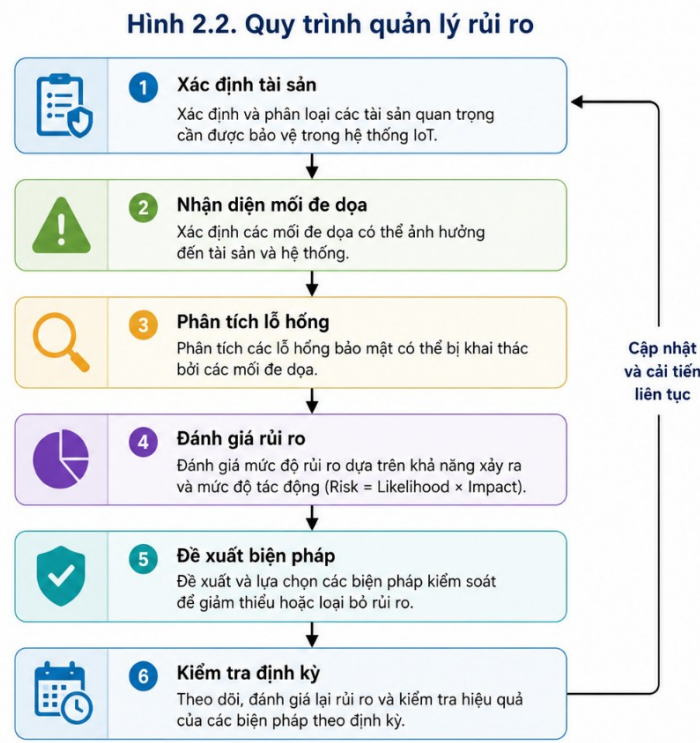
Rủi ro (Risk): Rủi ro là khả năng xảy ra sự cố bảo mật khi một mối đe dọa khai thác thành công lỗ hổng của hệ thống và gây ra thiệt hại đối với tài sản. Trong đề tài, mức độ rủi ro được đánh giá theo công thức: $Risk = Likelihood \times Impact$, trong đó Likelihood là khả năng xảy ra và Impact là mức độ ảnh hưởng của sự cố.

Mô hình CIA gồm ba thuộc tính cơ bản: Confidentiality (tính bí mật) đảm bảo dữ liệu chỉ được truy cập bởi các đối tượng được phép; Integrity (tính toàn vẹn) đảm bảo dữ liệu không bị thay đổi trái phép trong quá trình lưu trữ hoặc truyền tải; Availability (tính sẵn sàng) đảm bảo hệ thống luôn sẵn sàng phục vụ người dùng khi cần thiết.

Xác thực và phân quyền: Xác thực (Authentication) là quá trình kiểm tra danh tính của người dùng hoặc thiết bị trước khi cho phép truy cập hệ thống. Sau khi xác thực thành công, cơ chế phân quyền (Authorization) sẽ quyết định các chức năng mà người dùng được phép thực hiện.

Firmware: Firmware là chương trình điều khiển được cài đặt trực tiếp trên thiết bị IoT. Nếu firmware tồn tại lỗ hổng hoặc không được cập nhật định kỳ, thiết bị dễ bị khai thác; do đó firmware cần được cập nhật thường xuyên để khắc phục lỗ hổng bảo mật.

Đề tài thuộc Hướng G – Quản trị rủi ro, chính sách, checklist và kiểm thử, vì vậy nội dung được vận dụng theo một quy trình quản lý rủi ro gồm các bước: xác định tài sản, nhận diện mối đe dọa và lỗ hổng, đánh giá mức độ rủi ro, đề xuất biện pháp giảm thiểu và kiểm tra định kỳ (Hình 2.2). Quy trình này là khung tham chiếu xuyên suốt cho Chương 3 và Chương 6 của báo cáo.



Hình 2.2. Quy trình quản lý rủi ro. Nguồn: ChatGPT (OpenAI), nhóm tác giả hiệu chỉnh (2026).

2.3. Chuẩn, tài liệu và công cụ GitHub

STT	Nguồn/repo	URL	Phần đã sử dụng	Ngày truy cập
1	OWASP IoT Security Verification Standard (ISVS)	github.com/OWASP/IoT-Security-Verification-Standard-ISVS	Khung yêu cầu bảo mật (communication, software, hardware, data protection) dùng để xây dựng risk register và checklist kiểm tra định kỳ	04/07/2026
2	OWASP IoT Security Testing Guide (ISTG)	github.com/OWASP/owasp-istg	Tham khảo phương pháp/quy trình kiểm tra từng hạng mục trong checklist	04/07/2026
3	OWASP Internet of Things Project	github.com/OWASP/www-project-internet-of-things	Tổng hợp OWASP IoT Top 10 – nhóm rủi ro phổ biến dùng làm cơ sở xác định mối đe dọa/lỗ hổng trong risk register	04/07/2026
4	Practical IoT Security	— (sách in)	Khái niệm quản lý rủi ro, các	—

STT	Nguồn/repo	URL	Phần đã sử dụng	Ngày truy cập
	(B. Russell, D. Van Duren, Packt, 2016)		thành phần rủi ro (tài sản – mối đe dọa – lỗ hổng)	
5	IoT Security Guidelines Ver. 1.0 – IoT Acceleration Consortium, MIC, METI (2016)	— (tài liệu chính phủ Nhật Bản)	Tham khảo khung hướng dẫn bảo mật IoT tổng quát	—
6	Node-RED (node-red community)	github.com/node-red/node-red	Tham khảo vai trò gateway trong mô hình hệ thống (không dùng code demo)	04/07/2026

2.4. Công trình/giải pháp liên quan

Đề tài kế thừa các hướng dẫn của OWASP và NIST để xây dựng mô hình quản lý rủi ro phù hợp với hệ thống IoT quy mô nhỏ, bao gồm nhận diện tài sản, phân tích mối đe dọa, xây dựng Risk Register, đánh giá rủi ro theo ma trận 5×5 và đề xuất các biện pháp giảm thiểu.

3. PHƯƠNG PHÁP VÀ THIẾT KẾ

Chương này trình bày phương pháp nghiên cứu, mô hình hệ thống, môi trường triển khai và quy trình đánh giá rủi ro được sử dụng trong đề tài. Nội dung được xây dựng dựa trên các hướng dẫn của OWASP IoT Security Project, OWASP IoT Security Verification Standard (ISVS) và NIST SP 800-30 nhằm đảm bảo quá trình đánh giá rủi ro có tính hệ thống, phù hợp với các hệ thống IoT quy mô nhỏ.

3.1. Phương pháp thực hiện

Đề tài áp dụng phương pháp quản lý rủi ro bảo mật kết hợp với phương pháp phân tích định tính (Qualitative Risk Assessment) để nhận diện và đánh giá các nguy cơ đối với hệ thống IoT quy mô nhỏ. Phương pháp này phù hợp với các hệ thống có quy mô nhỏ, số lượng thiết bị không lớn và chưa có đầy đủ dữ liệu thống kê để thực hiện đánh giá định lượng.

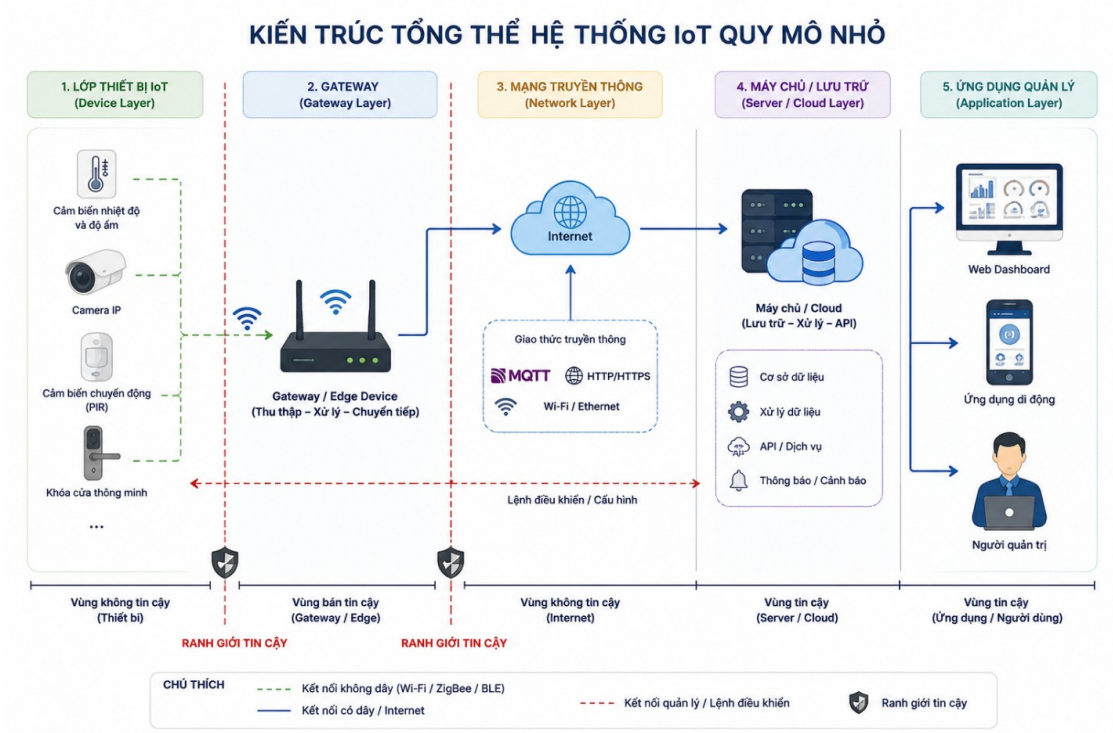
Việc đánh giá rủi ro được thực hiện theo hướng tiếp cận dựa trên tài sản (Asset-Based Risk Assessment), trong đó mỗi tài sản sẽ được phân tích dựa trên các mối đe dọa, lỗ hổng và tác động có thể xảy ra nhằm xác định mức độ ưu tiên xử lý.

3.2. Kiến trúc/mô hình và luồng dữ liệu

Mô hình nghiên cứu của đề tài mô phỏng một hệ thống IoT quy mô nhỏ gồm các thành phần cơ bản như thiết bị IoT, gateway, mạng truyền thông, máy chủ quản lý và người quản trị hệ thống. Đây là mô hình phổ biến được triển khai trong các hộ gia đình, phòng thí nghiệm và doanh nghiệp nhỏ.

Luồng truyền dữ liệu của hệ thống: Thiết bị IoT → Gateway → Server/Cloud → Ứng dụng quản lý → Người quản trị.

Để đảm bảo an toàn thông tin, đề tài xem xét các lớp bảo mật chính trong kiến trúc hệ thống gồm: bảo mật thiết bị IoT; bảo mật gateway; bảo mật mạng truyền thông; bảo mật máy chủ và cơ sở dữ liệu; bảo mật ứng dụng quản lý; quản lý người dùng và phân quyền truy cập.



Hình 3.1. Kiến trúc đề xuất của hệ thống IoT quy mô nhỏ. Nguồn: ChatGPT (OpenAI), nhóm tác giả hiệu chỉnh (2026).

3.3. Môi trường, công cụ và dữ liệu

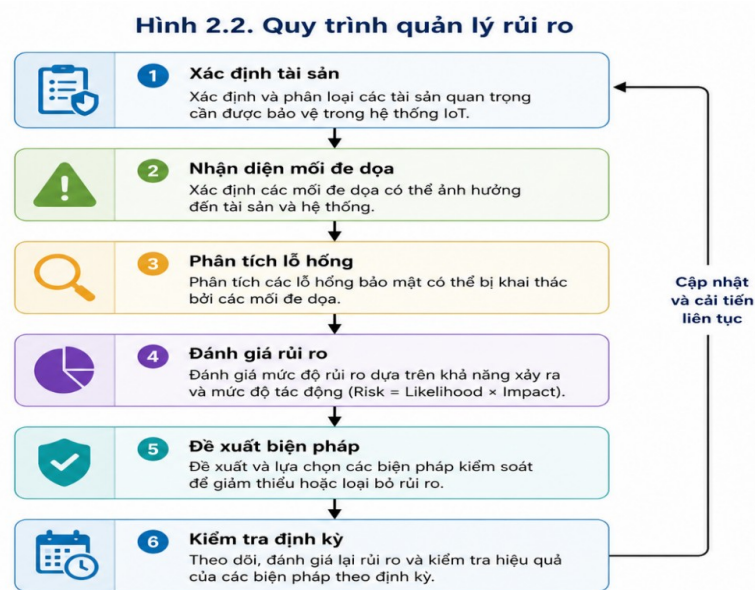
Công cụ	Mục đích sử dụng
Microsoft Word	Soạn thảo báo cáo
Draw.io	Thiết kế sơ đồ kiến trúc và quy trình
Microsoft Excel	Xây dựng Risk Register và ma trận rủi ro
GitHub	Quản lý tài liệu và lưu trữ sản phẩm
OWASP IoT Security	Tham khảo các lỗ hổng và hướng dẫn bảo mật
NIST SP 800-30	Hướng dẫn đánh giá rủi ro
NISTIR 8259	Tham khảo yêu cầu bảo mật thiết bị IoT

3.4. Quy trình thực hiện

Quy trình thực hiện đề tài được xây dựng theo mô hình quản lý rủi ro gồm sáu bước liên tiếp nhằm đảm bảo việc đánh giá được thực hiện đầy đủ và có hệ thống.

Bước 1. Xây dựng mô hình hệ thống IoT: xác định các thành phần của hệ thống, bao gồm thiết bị IoT, gateway, máy chủ và ứng dụng quản lý.

- Bước 2. Xác định tài sản cần bảo vệ: liệt kê các tài sản quan trọng như thiết bị, dữ liệu, tài khoản quản trị, firmware và cơ sở dữ liệu.
- Bước 3. Nhận diện mối đe dọa và lỗ hổng: phân tích các nguy cơ có thể xảy ra đối với từng tài sản, đồng thời xác định các điểm yếu có khả năng bị khai thác.
- Bước 4. Đánh giá mức độ rủi ro: mức độ rủi ro được xác định dựa trên công thức $Risk = Likelihood \times Impact$, trong đó Likelihood là khả năng xảy ra và Impact là mức độ ảnh hưởng khi rủi ro xảy ra.
- Bước 5. Đề xuất biện pháp giảm thiểu: đề xuất các giải pháp kỹ thuật và quản lý nhằm giảm khả năng xảy ra hoặc giảm mức độ ảnh hưởng của từng rủi ro.
- Bước 6. Đánh giá rủi ro còn lại: sau khi áp dụng các biện pháp kiểm soát, tiến hành đánh giá lại để xác định mức độ rủi ro còn lại và khả năng chấp nhận của hệ thống.



Hình 3.2. Quy trình triển khai đánh giá rủi ro. Nguồn: ChatGPT (OpenAI), nhóm tác giả hiệu chỉnh (2026).

3.5. Giới hạn an toàn và đạo đức

Hệ thống chỉ được sử dụng trong môi trường học tập và thử nghiệm, không dùng để tấn công hoặc xâm nhập trái phép vào các hệ thống khác. Dữ liệu sử dụng là dữ liệu mẫu hoặc dữ liệu đã được cho phép. Các thông tin như mật khẩu, tài khoản hoặc khóa bảo mật cần được lưu trữ an toàn và không công khai trong mã nguồn. Người sử dụng phải tuân thủ các quy định về an toàn thông tin và đạo đức nghề nghiệp.

4. TRIỂN KHAI VÀ SẢN PHẨM

4.1. Chuẩn bị môi trường

Quá trình triển khai được thực hiện trên môi trường mô phỏng nhằm đảm bảo an toàn, không tác động đến hệ thống thực tế. Toàn bộ dữ liệu tài sản, mối đe dọa và kịch bản rủi ro được xây dựng dựa trên

khảo sát một mô hình IoT quy mô nhỏ điển hình (hộ gia đình/phòng thí nghiệm), tham chiếu theo hướng dẫn của OWASP và NIST SP 800-30.

4.2. Thành phần sản phẩm

Đề tài đã xây dựng đầy đủ các sản phẩm đề ra tại mục 1.5:

STT	Thành phần	Vị trí lưu trữ	Chức năng	Người thực hiện
1	Sơ đồ kiến trúc tổng thể và sơ đồ quy trình quản lý rủi ro	report/ (Hình 2.1, 2.2, 3.1)	Mô tả kiến trúc hệ thống và quy trình đánh giá rủi ro	Võ Nguyễn Duyên
2	Danh mục 15 tài sản cần bảo vệ	report/ (Bảng 6.1)	Phân loại tài sản theo giá trị và vùng tin cậy	Võ Nguyễn Duyên
3	Risk Register (17 rủi ro)	results/ (Bảng 6.2)	Tổng hợp mối đe dọa, lỗ hổng và mức độ rủi ro	Võ Nguyễn Duyên
4	Ma trận đánh giá rủi ro 5×5	results/ (Bảng 6.3)	Trực quan hóa và phân loại mức độ rủi ro	Võ Nguyễn Duyên
5	Kế hoạch xử lý 5 rủi ro cao nhất	results/ (Bảng 6.4)	Đề xuất biện pháp giảm thiểu ưu tiên	Võ Nguyễn Duyên
6	Checklist kiểm tra bảo mật định kỳ (15 hạng mục)	results/ (Bảng 6.5)	Giám sát và duy trì mức an toàn theo chu kỳ	Võ Nguyễn Duyên
7	README	repo gốc	Mô tả phạm vi, tài liệu tham khảo và hướng dẫn sử dụng	Võ Nguyễn Duyên

4.3. Kịch bản thử nghiệm/đánh giá

Quy trình đánh giá rủi ro được áp dụng theo 6 bước mô tả tại Hình 2.2: xác định tài sản, nhận diện mối đe dọa, phân tích lỗ hổng, đánh giá rủi ro ($Risk = Likelihood \times Impact$), đề xuất biện pháp và kiểm tra định kỳ.

Ví dụ minh họa với tài sản Gateway: tài sản được xác định có giá trị cao nhất (5/5) do là điểm tập trung giao tiếp của toàn hệ thống; mối đe dọa được nhận diện là khai thác lỗ hổng để chiếm quyền điều khiển; lỗ hổng tương ứng là gateway không được cập nhật firmware định kỳ; với khả năng xảy ra ở mức 4/5 và mức ảnh hưởng 5/5, rủi ro R-02 đạt điểm số 20 – xếp mức Nghiêm trọng. Tương tự, với tài sản Khóa cửa thông minh, mối đe dọa mở khóa trái phép bằng tấn công lặp lại tín hiệu (replay attack) được đánh giá ở mức Rất cao (điểm số 15) do ảnh hưởng trực tiếp đến an ninh vật lý. Toàn bộ 17 kịch bản rủi ro được đánh giá theo cách tiếp cận tương tự và tổng hợp trong Risk Register (Bảng 6.2).

ID	Mục tiêu kiểm tra	Tài sản	Kết quả áp dụng
TC-01	Kiểm tra khả năng nhận diện rủi ro do firmware cũ	Gateway	Xác định R-02 – mức Nghiêm trọng (20 điểm)
TC-02	Kiểm tra khả năng nhận diện rủi ro xác thực yếu	Tài khoản quản trị	Xác định R-04 – mức Nghiêm trọng (20 điểm)
TC-03	Kiểm tra khả năng nhận diện rủi ro vật lý	Khóa cửa thông minh	Xác định R-16 – mức Rất cao (15 điểm)
TC-04	Kiểm tra khả năng nhận diện	Camera IP	Xác định R-01 – mức Rất cao (16 điểm)

ID	Mục tiêu kiểm tra	Tài sản	Kết quả áp dụng
	rủi ro mật khẩu mặc định		điểm)
TC-05	Kiểm tra tính đầy đủ của Risk Register	Toàn bộ 15 tài sản	Tổng hợp đủ 17 rủi ro, không bỏ sót tài sản nào

4.4. Hướng dẫn chạy hoặc sử dụng sản phẩm

Các sản phẩm phân tích (Risk Register, ma trận rủi ro, kế hoạch xử lý, checklist) được lưu ở định dạng Excel/Word trong thư mục results/ và report/ của repo. Người dùng mở tệp Risk Register để tra cứu mức độ rủi ro theo từng tài sản, đối chiếu với ma trận 5×5 để xác định thứ tự ưu tiên xử lý, và sử dụng checklist tại Bảng 6.5 theo tần suất tuần/tháng/quý để duy trì việc kiểm tra bảo mật định kỳ. Hướng dẫn chi tiết được mô tả trong README của repo.

5. KẾT QUẢ VÀ THẢO LUẬN

5.1. Kết quả chính

Sau khi hoàn thành đánh giá, hệ thống ghi nhận tổng cộng 17 rủi ro bảo mật trên 15 tài sản, phân bố theo mức độ như sau: 2 rủi ro mức Nghiêm trọng, 4 rủi ro mức Rất cao, 4 rủi ro mức Cao và 7 rủi ro mức Trung bình; không ghi nhận rủi ro mức Thấp. Kết quả cho thấy nhóm rủi ro liên quan đến xác thực và quản lý truy cập (mật khẩu yếu, thiếu MFA, truy cập từ xa không kiểm soát) và nhóm liên quan đến cập nhật firmware chiếm tỷ trọng cao nhất trong các mức Nghiêm trọng và Rất cao, phù hợp với nhận định của OWASP IoT Security Project về các lỗ hổng phổ biến của thiết bị IoT. Ma trận rủi ro 5×5 (Bảng 6.3) trực quan hóa sự phân bố này và là cơ sở để xác định 5 rủi ro cần xử lý ưu tiên tại mục 6.4.

A1									
	A	B	C	D	E	F	G	H	I
1	STT	Tai_san	Loai_tai_san	Gia_tri_1_5	Vung_tin_cay				
2	1	Cam bien r	Thiet bi IoT	3	Vung khong tin cay (Device Zone)				
3	2	Camera IP	Thiet bi IoT	4	Vung khong tin cay (Device Zone)				
4	3	Cam bien c	Thiet bi IoT	3	Vung khong tin cay (Device Zone)				
5	4	Khoa cua t	Thiet bi IoT	5	Vung khong tin cay (Device Zone)				
6	5	Gateway /	Thiet bi ma	5	Vung ban tin cay (Gateway Zone)				
7	6	Firmware t	Phan mem	4	Vung khong tin cay (Device Zone)				
8	7	Du lieu car	Du lieu	3	Xuyen suot cac vung (Cross-zone)				
9	8	Tai khoan c	Dinh danh/	5	Vung tin cay (Application Zone)				
10	9	Co so du lie	Du lieu / Ha	5	Vung tin cay (Server/Cloud Zone)				
11	10	May chu / C	Ha tang	5	Vung tin cay (Server/Cloud Zone)				
12	11	Web Dashl	Phan mem	4	Vung tin cay (Application Zone)				
13	12	Ung dung d	Phan mem	4	Vung tin cay (Application Zone)				
14	13	Khoa ma h	Dinh danh/	5	Xuyen suot cac vung (Cross-zone)				
15	14	Ha tang m	Ha tang m	4	Vung khong tin cay (Internet Zone)				
16	15	Nhat ky he	Du lieu	3	Vung tin cay (Server/Cloud Zone)				
17									

Hình 5.1. Kết quả lập danh mục tài sản của hệ thống IoT. Nguồn: Nhóm tác giả (2026).

Phân tích: Danh mục tài sản xác định các thiết bị và thành phần quan trọng của hệ thống IoT, làm cơ sở cho quá trình đánh giá rủi ro.

POSSIBLE DATA LOSS Some features might be lost if you save this workbook in the comma-delimited (.csv) format. To preserve these features, s

	A	B	C	D	E	F	G	H	I	J	K	L
1	ID	Tai_san	Moi_de_do	Lo_hong	Kha_nang	Anh_huong	Diem_rui_r	Muc_do	Bien_phap	Nguai_phu	Trang_thai	
2	R-01	Camera IP	Truy cap tr	Su dung m	4	4	16	Rat cao	Doi mat kh	Administra	Hoan thanh	
3	R-02	Gateway	Khai thac li	Gateway k	4	5	20	Nghiem trc	Cap nhac fi	Administra	Dang thuc hien	
4	R-03	Du lieu car	Nghe len d	Du lieu truy	3	3	9	Trung binh	Bat TLS va i	Operator	Hoan thanh	
5	R-04	Tai khoan c	Chiem quy	Mat khau y	5	4	20	Nghiem trc	Ap dung MI	Administra	Dang thuc hien	
6	R-05	May chu /	Truy cap tr	Cau hinh s	3	4	12	Cao	Ra soat cai	System Adi	Dang thuc hien	
7	R-06	Firmware t	Khai thac li	Firmware l	4	4	16	Rat cao	Nang cap f	Administra	Dang thuc hien	
8	R-07	Gateway /	Gia mao th	Giao thuc l	3	3	9	Trung binh	Su dung TL	Operator	Hoan thanh	
9	R-08	Ha tang m	Lan truyen	Mang noi b	2	3	6	Trung binh	Phan doan	Network A	Ke hoach	
10	R-09	Nhat ky he	Khong phai	Thieu co cl	4	3	12	Cao	Trien khai l	System Adi	Dang thuc hien	
11	R-10	Gateway /	Tan cong ti	Thieu co cl	2	4	8	Trung binh	Cau hinh r	Network A	Ke hoach	
12	R-11	Ung dung c	Khai thac li	Ung dung c	3	4	12	Cao	Kiem thu b	Developer	Dang thuc hien	
13	R-12	Co so du li	Mat du lieu	Sao lưu du	2	3	6	Trung binh	Thiet lap s	Database	Hoan thanh	
14	R-13	Khoa ma h	Lo khoa m	Quan ly va	2	4	8	Trung binh	Luu tru khc	Security Ac	Ke hoach	
15	R-14	Ung dung c	Truy cap tr	Cho phep t	4	4	16	Rat cao	Gioi han IP	Network A	Dang thuc hien	
16	R-15	Nguai dung	Bi lua dao	(Thieu nhan	4	3	12	Cao	Dao tao nh	Administra	Ke hoach	
17	R-16	Khoa cua ti	Mo khoa tr	Giao thuc l	3	5	15	Rat cao	Su dung m	Administra	Dang thuc hien	
18	R-17	Cam bien c	Gia mao/v	Thieu co cl	2	3	6	Trung binh	Bo sung he	Operator	Ke hoach	
19												

Hình 5.2. Kết quả xây dựng Risk Register. Nguồn: Nhóm tác giả (2026).

Phân tích: Risk Register tổng hợp các rủi ro, mức độ ảnh hưởng, khả năng xảy ra và biện pháp xử lý tương ứng.

	A	B	C	D	E	F	G
1	Kha_nang	1	2	3	4	5	
2	5	5	10	15	20 (R-04)	25	
3	4	4	8	12 (R-09; R	16 (R-01; R	20 (R-02)	
4	3	3	6	9 (R-03; R-	12 (R-05; R	15 (R-16)	
5	2	2	4	6 (R-08; R-	8 (R-10; R-	10	
6	1	1	2	3	4	5	
7							

Hình 5.3. Ma trận đánh giá rủi ro 5×5. Nguồn: Nhóm tác giả (2026).

Phân tích: Ma trận giúp phân loại mức độ rủi ro để ưu tiên xử lý các rủi ro nghiêm trọng trước.

5.2. Bảng tổng hợp kết quả

Tiêu chí (mục tiêu)	Kỳ vọng	Kết quả thực tế	Đạt/Chưa đạt	Minh chứng
MT-01: Xác định tài sản	Phân loại tài sản quan trọng	15 tài sản, phân theo 5 lớp và vùng tin cậy	Đạt	Bảng 6.1
MT-02: Phân tích đe dọa/lỗ hỏng	Đánh giá rủi ro từng tài sản	17 cặp đe dọa – lỗ hỏng được phân tích	Đạt	Bảng 6.2
MT-03: Risk Register và ma trận 5×5	Tối thiểu 15 rủi ro	17 rủi ro, ma trận 5×5 đầy đủ	Đạt	Bảng 6.2, 6.3
MT-04: Kế hoạch xử lý	Đề xuất xử lý rủi ro cao nhất	Kế hoạch xử lý cho 5 rủi ro ưu tiên	Đạt	Bảng 6.4
MT-05: Checklist định kỳ	Xây dựng checklist kiểm tra	Checklist 15 hạng mục theo tuần/tháng/quý	Đạt	Bảng 6.5

5.3. Đối chiếu mục tiêu

Đối chiếu với 5 mục tiêu đề ra tại mục 1.3, đề tài đã hoàn thành đầy đủ: (MT-01) đã xác định và phân loại 15 tài sản quan trọng của hệ thống IoT quy mô nhỏ theo giá trị và vùng tin cậy; (MT-02) đã phân tích 17 mối đe dọa và lỗ hổng bảo mật tương ứng; (MT-03) đã xây dựng Risk Register và ma trận đánh giá rủi ro 5×5, xác định rõ 2 rủi ro mức Nghiêm trọng và 4 rủi ro mức Rất cao; (MT-04) đã đề xuất kế hoạch xử lý chi tiết cho 5 rủi ro có mức độ cao nhất; và (MT-05) đã xây dựng checklist kiểm tra bảo mật định kỳ gồm 15 hạng mục theo tần suất tuần/tháng/quý/6 tháng. Toàn bộ mục tiêu đều có minh chứng bằng bảng dữ liệu và hình ảnh kết quả tương ứng.

5.4. Hạn chế

Bên cạnh các kết quả đạt được, đề tài còn tồn tại một số hạn chế. Thứ nhất, dữ liệu và kịch bản sử dụng trong đánh giá là dữ liệu giả lập, chưa được kiểm chứng trên hệ thống IoT vận hành thực tế. Thứ hai, phương pháp đánh giá định tính phụ thuộc vào kinh nghiệm và nhận định chủ quan của người đánh giá khi gán điểm Likelihood và Impact, có thể dẫn đến sai lệch so với thực tế. Thứ ba, đề tài chưa thực hiện kiểm thử xâm nhập (penetration testing) hay quét lỗ hổng tự động để xác thực các rủi ro đã nhận diện bằng dữ liệu định lượng. Cuối cùng, phạm vi nghiên cứu giới hạn ở quy mô hộ gia đình/phòng thí nghiệm nên chưa đại diện đầy đủ cho các hệ thống IoT quy mô lớn hơn.

6. ĐÁNH GIÁ BẢO MẬT

Chương này tập trung vào việc đánh giá mức độ rủi ro của hệ thống IoT quy mô nhỏ dựa trên các tài sản cần bảo vệ, các mối đe dọa và lỗ hổng bảo mật đã được nhận diện. Đồng thời, chương cũng trình bày các biện pháp giảm thiểu và đánh giá rủi ro còn lại sau khi áp dụng các giải pháp bảo mật.

6.1. Tài sản và dữ liệu cần bảo vệ

Hệ thống IoT quy mô nhỏ được khảo sát bao gồm 15 tài sản thuộc 5 lớp kiến trúc: thiết bị IoT, gateway, mạng truyền thông, máy chủ/lưu trữ và ứng dụng quản lý. Các tài sản được phân loại theo giá trị và vùng tin cậy nhằm xác định mức độ ưu tiên bảo vệ. Trong đó, các tài sản như Gateway, tài khoản quản trị, cơ sở dữ liệu và máy chủ có giá trị cao nhất vì ảnh hưởng trực tiếp đến tính bảo mật, toàn vẹn và khả năng hoạt động của hệ thống.

Tài sản	Loại tài sản	Giá trị (1-5)	Vùng tin cậy
Cảm biến nhiệt độ/độ ẩm	Thiết bị IoT	3	Vùng không tin cậy (Thiết bị)
Camera IP	Thiết bị IoT	4	Vùng không tin cậy (Thiết bị)
Cảm biến chuyển động (PIR)	Thiết bị IoT	3	Vùng không tin cậy (Thiết bị)
Khóa cửa thông minh	Thiết bị IoT	5	Vùng không tin cậy (Thiết bị)
Gateway / Edge Device	Thiết bị mạng	5	Vùng bán tin cậy (Gateway/Edge)
Firmware thiết bị	Phần mềm nhúng	4	Vùng không tin cậy / bán tin cậy
Dữ liệu cảm biến	Dữ liệu	3	Xuyên suốt các vùng
Tài khoản quản trị	Định danh/Truy cập	5	Vùng tin cậy (Ứng dụng/Người)

Tài sản	Loại tài sản	Giá trị (1-5)	Vùng tin cậy
			dùng)
Cơ sở dữ liệu (Database)	Dữ liệu/Hạ tầng	5	Vùng tin cậy (Server/Cloud)
Máy chủ / Cloud server	Hạ tầng	5	Vùng tin cậy (Server/Cloud)
Web Dashboard	Phần mềm	4	Vùng tin cậy (Ứng dụng/Người dùng)
Ứng dụng di động (Mobile App)	Phần mềm	4	Vùng tin cậy (Ứng dụng/Người dùng)
Khóa mã hóa (Encryption keys)	Định danh/Bảo mật	5	Xuyên suốt các vùng
Hạ tầng mạng nội bộ/Internet	Hạ tầng mạng	4	Vùng bán tin cậy/không tin cậy
Nhật ký hệ thống (Log)	Dữ liệu	3	Vùng tin cậy (Server/Cloud)

Bảng 6.1. Danh mục tài sản của hệ thống IoT quy mô nhỏ

6.2. Môi đe dọa và lỗ hổng

Từ 15 tài sản đã xác định, đề tài nhận diện được 17 cặp mối đe dọa – lỗ hổng, mỗi cặp được gán mức Khả năng xảy ra (L) và Tác động (I) theo thang 1-5 để tính điểm rủi ro ($Risk = L \times I$). Các rủi ro chủ yếu liên quan đến mật khẩu yếu, firmware chưa cập nhật, truyền dữ liệu không mã hóa, cấu hình hệ thống chưa an toàn và thiếu cơ chế giám sát.

ID	Tài sản	Mối đe dọa	Lỗ hổng	L	I	Mức độ
R-01	Camera IP	Truy cập trái phép vào thiết bị	Sử dụng mật khẩu mặc định của nhà sản xuất	4	4	Rất cao
R-02	Gateway	Khai thác lỗ hổng để chiếm quyền điều khiển	Gateway không được cập nhật firmware định kỳ	4	5	Nghiêm trọng
R-03	Dữ liệu cảm biến	Nghe lén dữ liệu trong quá trình truyền tải	Dữ liệu truyền giữa thiết bị và gateway không được mã hóa	3	3	Trung bình
R-04	Tài khoản quản trị	Chiếm quyền tài khoản quản trị	Mật khẩu yếu, không áp dụng MFA	5	4	Nghiêm trọng
R-05	Máy chủ / Cloud server	Truy cập trái phép vào máy chủ	Cấu hình sai, mở các cổng dịch vụ không cần thiết	3	4	Cao
R-06	Firmware thiết bị	Khai thác lỗ hổng đã công bố (CVE)	Firmware lỗi thời, không còn được nhà sản xuất hỗ trợ	4	4	Rất cao
R-07	Gateway / MQTT	Giả mạo thiết bị, chèn dữ liệu giả	Giao thức MQTT không xác thực và không mã hóa	3	3	Trung bình
R-08	Hạ tầng mạng nội bộ	Lan truyền tấn công giữa các thiết bị	Mạng nội bộ không được phân đoạn (VLAN)	2	3	Trung bình
R-09	Nhật ký hệ thống	Không phát hiện kịp	Thiếu cơ chế giám sát và	4	3	Cao

ID	Tài sản	Mối đe dọa	Lỗ hổng	L	I	Mức độ
	(Log)	thời sự cố bảo mật	ghi log hoạt động hệ thống			
R-10	Gateway / Máy chủ	Tấn công từ chối dịch vụ (DoS)	Thiếu cơ chế giới hạn tốc độ truy cập (rate limiting)	2	4	Trung bình
R-11	Ứng dụng quản lý	Khai thác lỗ hổng ứng dụng web (XSS, SQLi)	Ứng dụng quản lý chưa kiểm thử bảo mật đầy đủ	3	4	Cao
R-12	Cơ sở dữ liệu	Mất dữ liệu khi xảy ra sự cố	Sao lưu dữ liệu không đầy đủ hoặc không định kỳ	2	3	Trung bình
R-13	Khóa mã hóa	Lộ khóa mã hóa dẫn đến giải mã dữ liệu trái phép	Quản lý và lưu trữ khóa mã hóa không chặt chẽ	2	4	Trung bình
R-14	Ứng dụng quản lý / Server	Truy cập trái phép từ xa vào hệ thống quản lý	Cho phép truy cập từ xa không giới hạn IP, không dùng VPN	4	4	Rất cao
R-15	Người dùng / Quản trị viên	Bị lừa đảo (phishing) dẫn đến lộ thông tin đăng nhập	Thiếu nhận thức và đào tạo về an toàn thông tin	4	3	Cao
R-16	Khóa cửa thông minh	Mở khóa trái phép từ xa (replay attack)	Giao thức không dây (Wi-Fi/ZigBee/BLE) thiếu mã hóa	3	5	Rất cao
R-17	Cảm biến chuyển động (PIR)	Giả mạo/vô hiệu hóa cảm biến	Thiếu cơ chế giám sát tình trạng hoạt động (heartbeat)	2	3	Trung bình

Bảng 6.2. Sổ đăng ký rủi ro (Risk Register)

6.3. Ma trận rủi ro

Ma trận đánh giá rủi ro 5×5 được xây dựng dựa trên công thức $Risk = Likelihood \times Impact$, với 5 mức phân loại: Thấp (1-4), Trung bình (5-9), Cao (10-14), Rất cao (15-19) và Nghiêm trọng (20-25). Kết quả cho thấy 2 rủi ro (R-02, R-04) rơi vào mức Nghiêm trọng, cần xử lý ngay; 4 rủi ro (R-01, R-06, R-14, R-16) ở mức Rất cao; 4 rủi ro ở mức Cao và 7 rủi ro ở mức Trung bình. Không có rủi ro nào rơi vào mức Thấp, cho thấy hệ thống IoT quy mô nhỏ được khảo sát còn thiếu nhiều cơ chế bảo mật nền tảng và cần được ưu tiên cải thiện toàn diện.

Likelihood \ Impact	1	2	3	4	5
5	5	10	15	20 (R-04)	25
4	4	8	12 (R-09, R-15)	16 (R-01, R-06, R-14)	20 (R-02)
3	3	6	9 (R-03, R-07)	12 (R-05, R-11)	15 (R-16)
2	2	4	6 (R-08, R-12, R-17)	8 (R-10, R-13)	10

Likelihood \ Impact	1	2	3	4	5
1	1	2	3	4	5

Bảng 6.3. Ma trận đánh giá rủi ro 5×5

6.4. Biện pháp giảm thiểu và ưu tiên

ID	Rủi ro	Mức độ	Biện pháp giảm thiểu	Rủi ro còn lại
R-02	Gateway không cập nhật firmware định kỳ	Nghiêm trọng	Thiết lập lịch cập nhật firmware định kỳ; đăng ký nhận cảnh báo bảo mật (security advisory) từ nhà sản xuất; kiểm thử firmware trước khi triển khai.	Cao → Trung bình
R-04	Tài khoản quản trị dùng mật khẩu yếu, không có MFA	Nghiêm trọng	Áp dụng chính sách mật khẩu mạnh, bắt buộc xác thực đa yếu tố (MFA); khóa tài khoản sau nhiều lần đăng nhập sai.	Cao → Thấp
R-16	Khóa cửa thông minh bị mở khóa trái phép (replay attack)	Rất cao	Áp dụng mã hóa và cơ chế chống lặp lại tín hiệu (rolling code); giới hạn khoảng cách kết nối; cảnh báo khi có yêu cầu mở khóa bất thường.	Trung bình → Thấp
R-01	Camera IP sử dụng mật khẩu mặc định	Rất cao	Bắt buộc đổi mật khẩu mặc định khi cài đặt; vô hiệu hóa tài khoản mặc định; đặt thiết bị trong VLAN riêng.	Trung bình → Thấp
R-06	Firmware thiết bị lỗi thời chứa CVE đã công bố	Rất cao	Thay thế thiết bị không còn được hỗ trợ; quét lỗ hổng định kỳ; vá lỗi ngay khi có bản cập nhật.	Trung bình → Thấp

Bảng 6.4. Kế hoạch xử lý 5 rủi ro có mức độ cao nhất

Nhóm	Hạng mục kiểm tra	Tần suất
Thiết bị IoT	Kiểm tra thiết bị còn dùng mật khẩu mặc định	Hàng tháng
Thiết bị IoT	Kiểm tra phiên bản firmware, cập nhật bản vá mới nhất	Hàng tháng
Thiết bị IoT	Kiểm tra khóa cửa thông minh, không có dấu hiệu can thiệp tín hiệu	Hàng tuần
Thiết bị IoT	Kiểm tra cảm biến PIR hoạt động bình thường (heartbeat)	Hàng tuần
Gateway	Kiểm tra cấu hình xác thực, phân quyền trên gateway	Hàng tháng
Gateway	Kiểm tra log truy cập gateway, phát hiện bất thường	Hàng tuần
Mạng truyền thông	Kiểm tra dữ liệu truyền có mã hóa TLS/HTTPS	Hàng quý
Mạng truyền thông	Kiểm tra phân đoạn mạng (VLAN)	Hàng quý
Máy chủ / CSDL	Kiểm tra bản sao lưu dữ liệu gần nhất	Hàng tuần
Máy chủ / CSDL	Kiểm tra vá lỗi hệ điều hành, phần mềm máy chủ	Hàng tháng
Tài khoản & truy cập	Kiểm tra chính sách mật khẩu và MFA	Hàng quý
Tài khoản & truy cập	Kiểm tra giới hạn truy cập từ xa (VPN, IP allowlist)	Hàng quý

Nhóm	Hạng mục kiểm tra	Tần suất
Ứng dụng quản lý	Kiểm thử lỗ hổng ứng dụng web (XSS, SQLi)	Hàng quý
Giám sát & ứng phó	Kiểm tra hệ thống log/cảnh báo hoạt động bình thường	Hàng tuần
Con người	Đào tạo nhận thức an toàn thông tin	6 tháng/lần

Bảng 6.5. Checklist kiểm tra bảo mật định kỳ

6.5. Đánh giá an toàn sau xử lý

Sau khi áp dụng các biện pháp kiểm soát đề xuất tại mục 6.4, mức độ rủi ro của 5 rủi ro ưu tiên được kỳ vọng giảm từ Nghiêm trọng/Rất cao xuống còn Trung bình hoặc Thấp (Bảng 6.4). Các rủi ro còn lại sau xử lý (residual risk) chủ yếu liên quan đến yếu tố con người và các mối đe dọa mới phát sinh (zero-day), vốn không thể loại bỏ hoàn toàn mà chỉ có thể giảm thiểu. Mức rủi ro còn lại này được xem là có thể chấp nhận được (acceptable risk) đối với quy mô và nguồn lực của hệ thống IoT nhỏ, với điều kiện checklist bảo mật định kỳ (Bảng 6.5) được thực hiện nghiêm túc và quy trình quản lý rủi ro (Hình 2.2) được lặp lại theo chu kỳ để cập nhật, cải tiến liên tục.

7. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

7.1. Kết luận

Đề tài đã hoàn thành đầy đủ 5 mục tiêu đề ra tại mục 1.3. Cụ thể: (MT-01) đã xác định và phân loại 15 tài sản quan trọng của hệ thống IoT quy mô nhỏ theo giá trị và vùng tin cậy; (MT-02) đã phân tích 17 mối đe dọa và lỗ hổng bảo mật tương ứng; (MT-03) đã xây dựng Risk Register và ma trận đánh giá rủi ro 5×5, xác định rõ 2 rủi ro mức Nghiêm trọng và 4 rủi ro mức Rất cao; (MT-04) đã đề xuất kế hoạch xử lý chi tiết cho 5 rủi ro có mức độ cao nhất; và (MT-05) đã xây dựng checklist kiểm tra bảo mật định kỳ gồm 15 hạng mục theo tần suất tuần/tháng/quý/6 tháng. Kết quả nghiên cứu cho thấy quy trình quản lý rủi ro dựa trên tài sản (Asset-Based Risk Assessment), kết hợp hướng dẫn của OWASP và NIST SP 800-30, là cách tiếp cận phù hợp và khả thi để nâng cao mức độ an toàn thông tin cho các hệ thống IoT quy mô nhỏ.

7.2. Hướng phát triển

Trong tương lai, đề tài có thể được mở rộng theo các hướng sau: (1) áp dụng mô hình quản lý rủi ro trên hệ thống IoT thực tế với thiết bị vật lý để kiểm chứng kết quả; (2) bổ sung phương pháp đánh giá rủi ro định lượng (Quantitative Risk Assessment) dựa trên dữ liệu thống kê sự cố thực tế; (3) tích hợp các công cụ giám sát bảo mật tự động (SIEM, IDS/IPS) để phát hiện và cảnh báo rủi ro theo thời gian thực; (4) thực hiện kiểm thử xâm nhập định kỳ theo hướng dẫn OWASP ISTG để xác thực hiệu quả của các biện pháp giảm thiểu; và (5) mở rộng mô hình để áp dụng cho các hệ thống IoT quy mô vừa và lớn, hướng tới tuân thủ đầy đủ khung NIST Cybersecurity Framework (CSF).

TÀI LIỆU THAM KHẢO

- [1] OWASP Foundation. OWASP IoT Security Verification Standard (ISVS). <https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS>. Nhánh main. Truy cập ngày 04/07/2026.
- [2] OWASP Foundation. OWASP IoT Security Testing Guide (ISTG). <https://github.com/OWASP/owasp-istg>. Nhánh main. Truy cập ngày 04/07/2026.
- [3] OWASP Foundation. OWASP Internet of Things Project. <https://github.com/OWASP/www-project-internet-of-things>. Nhánh main. Truy cập ngày 04/07/2026.
- [4] OWASP Foundation. OWASP IoTGoat. <https://github.com/OWASP/IoTGoat>. Nhánh main. Truy cập ngày 04/07/2026.
- [5] National Institute of Standards and Technology (NIST). NIST Special Publication 800-30 Revision 1 – Guide for Conducting Risk Assessments. <https://csrc.nist.gov/pubs/sp/800/30/r1/final>. Revision 1, 2012. Truy cập ngày 04/07/2026.
- [6] National Institute of Standards and Technology (NIST). NISTIR 8259 – Foundational Cybersecurity Activities for IoT Device Manufacturers. <https://csrc.nist.gov/pubs/ir/8259/final>. 2020. Truy cập ngày 04/07/2026.

PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP

231A010722-vo-nguyen-duyen-quan-ly-rui-ro-iot/

README.md

report/ (báo cáo, sơ đồ Hình 2.1/2.2/3.1/3.2)

slides/ (bản trình chiếu .pptx)

results/ (Risk Register, ma trận 5x5, kế hoạch xử lý, checklist – Bảng 6.1-6.5)

references/ (tài liệu tham khảo OWASP, NIST)

PHỤ LỤC B. NHẬT KÝ ĐÓNG GÓP

ST T	Họ tên - MSSV	Công việc	Commit/file	Tỷ lệ (%)	Xác nhận
1	Võ Nguyễn Duyen - 231A010722	Toàn bộ nội dung: xác định tài sản, xây dựng Risk Register, ma trận rủi ro, kế hoạch xử lý, checklist và báo cáo	report/, results/	100%	☐

PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP

STT	Nội dung kiểm tra	Trạng thái
1	Báo cáo đủ 7 phần chính, mục lục và tài liệu tham khảo.	☐ Đạt ☐ Chưa đạt
2	Độ dài báo cáo chính 10-15 trang, không tính phụ lục.	☐ Đạt ☐ Chưa đạt
3	Repo mở được; README có cách chạy/sử dụng và mô tả cấu trúc.	☐ Đạt ☐ Chưa đạt
4	Có sản phẩm phân tích hoàn chỉnh (risk register, ma trận, checklist).	☐ Đạt ☐ Chưa đạt
5	Có ít nhất 3 minh chứng kiểm tra được (Hình 5.1-5.3).	☐ Đạt ☐ Chưa đạt
6	Có ít nhất 5 tài liệu tham khảo và repo GitHub/tool chính.	☐ Đạt ☐ Chưa đạt
7	Mọi hình/bảng có tên, số thứ tự, nguồn và phần phân tích.	☐ Đạt ☐ Chưa đạt
8	Không có secret, token, mật khẩu, dữ liệu cá nhân hoặc file nhạy cảm.	☐ Đạt ☐ Chưa đạt
9	Mọi thử nghiệm chỉ diễn ra trong môi trường local/được phép.	☐ Đạt ☐ Chưa đạt
10	Slide có 8-12 trang, link repo, kết quả chính, rủi ro và kết luận.	☐ Đạt ☐ Chưa đạt
11	Đã cập nhật mục lục, kiểm tra chính tả và xóa toàn bộ hướng dẫn mẫu.	☐ Đạt ☐ Chưa đạt

PHỤ LỤC D. PHIẾU TỰ ĐÁNH GIÁ THEO RUBRIC

Tiêu chí	Điểm tối đa	Tự chấm	Minh chứng/ghi chú
Đúng đề tài, đúng phạm vi	1,0		

Tiêu chí	Điểm tối đa	Tự chấm	Minh chứng/ghi chú
Nguồn GitHub và tài liệu tham khảo	1,0		
Cơ sở lý thuyết	1,0		
Cách làm/phương pháp	1,0		
Sản phẩm phân tích (risk register, ma trận, checklist)	2,0		
Phân tích bảo mật/rủi ro/biện pháp	1,5		
Trình bày, hình bảng và trích dẫn	1,0		
Slide và bảo vệ	1,0		
Tuân thủ an toàn và đạo đức	0,5		
TỔNG	10,0		

PHỤ LỤC E. CÂU HỎI CHUẨN BỊ BẢO VỆ

- Vấn đề bảo mật cốt lõi của đề tài là gì và vì sao đáng giải quyết?
- Sản phẩm chính nằm ở file/thư mục nào trong repo và sử dụng ra sao?
- Minh chứng nào thuyết phục nhất cho kết quả đạt được?
- Rủi ro nghiêm trọng nhất là gì; biện pháp giảm thiểu có giới hạn nào?
- Nếu có thêm thời gian, sẽ cải thiện điều gì đầu tiên?

PHỤ LỤC F. ĐỐI CHIẾU ĐỀ TÀI ĐƯỢC GIAO

Mã	Tên đề tài và hướng	Mục tiêu cần đạt	Sản phẩm/đầu ra bắt buộc
35	Quản lý rủi ro bảo mật cho hệ thống IoT quy mô nhỏ – Hướng G: Quản trị rủi ro, chính sách, checklist và kiểm thử	Xây dựng quy trình quản lý rủi ro cho hệ IoT nhỏ; tạo risk register và ma trận ưu tiên; đề xuất kế hoạch xử lý rủi ro.	Risk register tối thiểu 15 dòng; ma trận rủi ro 5x5; kế hoạch xử lý 5 rủi ro cao nhất; checklist kiểm tra định kỳ.